

체내 이식형 의료기기를 위한 경량화 인증 프로토콜 설계 및 정형화 검증

김지윤, 권순현, 고용호, 유일선*

순천향대학교 정보보호학과

e-mail : 74jykim@gmail.com, tnsqus08@gmail.com,

koyh0911@gmail.com, ilsunu@gmail.com

Design and Formal Security Analysis of Secured Authentication Protocol for Implantable Medical Device

Jiyeon Kim, Soonhyun Kwon, Yongho Ko, Ilsun You*

Dept of Information Security Engineering, Soonchunhyang University

요 약

IT 기술과 의료기기의 발달로 체내 이식형 의료기기가 개발되었다. 체내 이식형 의료기기는 환자의 체내에 이식한 의료기기를 통해 환자의 상태 모니터링 및 치료에 관한 전반적인 분야를 담당한다. 이를 활용하여 자주 병원에 방문하여 치료를 받아야 하는 환자의 경우에도 체내 이식형 의료기기를 활용하여 병원에 방문하지 않고 원격으로 진료를 받을 수 있는 환경이 조성되었다. 그러나 이러한 편의성은 무선 통신을 활용하기 때문에 개인정보 및 보안 취약점에 의하여 환자에게 치명적인 위협이 될 수 있다. 본 논문에서는 체내 이식형 의료기기를 위한 안전한 인증 프로토콜을 제안하고 이를 AVISPA를 통해 정형화 분석한다.

Keyword : IMD, Security, Wearable device, AVISPA

1. 서 론

안전한 의료 서비스를 제공받고자 하는 수요가 증가함에 따라 치료를 위한 의료기기도 꾸준히 발전하고 있다. IT 기술과 의료기기의 발달로 최근 체내 이식형 의료기기(IMD : Implantable Medical Device)가 개발되었고 이에 대한 수요도 증가하고 있다. 체내 이식형 의료기기에는 심장 박동기, 제세동기, 인슐린 펌프 등이 있다. 또한, 최근 wearable device가 개발됨에 따라 체내 이식형 의료기기 분야에도 패러다임의 변화가 진행되고 있으며 wearable 기술을 활용하여 체내에 이식된 의료기기가 환자의 다양한 신체 정보를 수집하여 환자에 적합한 치료를 수행하도록 개발되고 있다[1].

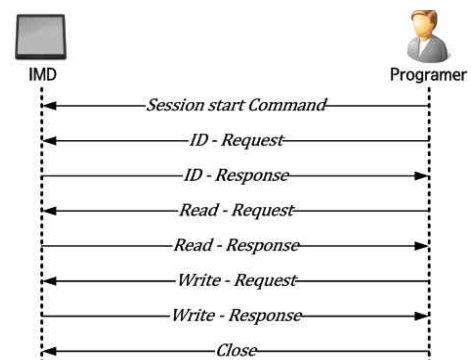
그러나 산업의 성장과 취급하는 정보의 중요성에 비하여 보안 관점에서의 접근은 미비하다. 체내 이식형 의료기기는 무선 통신을 활용하여 환자의 상태, 치료, 처방 정보를 전달하기 때문에 취약한 무선 통신을 활용할 경우 개인정보 침해의 위험이 뒤따르며 환자의 체내에 이식되어 있는 기기의 특성상 취약점을 통해 악용된다면 치명적인 위협이 된다[2]. 이에 대한 다양한 연구가 진행되어 다양한 프로토콜이 제안되었다[3,4]. 그러나 체내 이식형 의료기기의 제한된 자원 및 환경으로 인해 활용하기 어렵다. 본 논문에서는 기존의 2-Tier 모델을 확장한 3-Tier 모델을 활용하여 보안 프로토콜을 제안하고 이를 AVISPA(Automated Validation of Internet Security Protocols and Applications)를 통해 정형화 검증한다.

본 논문의 구성은 다음과 같다. 2장에서는 기존의 2-Tier 구조와 이를 확장한 3-Tier 구조에 대해 서술한다. 3장에서는 체내 이식형 의료기기의 보안 요구사항에 대해 서술하고, 보안 요구사항을 적용한 체내 이식형 의료기기를 위한 안전한 인증 프로토콜을 제안한다. 4장에서는 제안한 프로토콜을 AVISPA를 통해 정형화 검증하며, 마지막으로 5장에서 결론을 맺고 마무리한다.

2. 관련 연구

2.1 2-Tier 구조

본 논문에서 활용하는 3-Tier 구조는 기존의 2-Tier 구조를 확장한 것으로 현재 체내 이식형 의료기기에서는 2-Tier 구조를 채택하고 있다. 기존 2-Tier 구조는 그림 1과 같다.



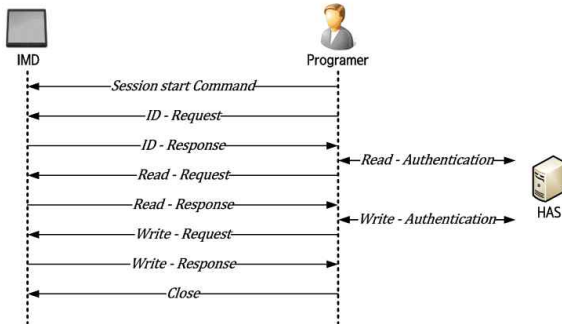
(그림 1) 2-Tier 구조 모델

2.2 3-Tier 구조

3-Tier 구조는 기존의 2-Tier 구조에서 활용하는 인증 및 통신에 필요한 연산을 다른 요소에 위임하는 구조로서 체내 이식형 의료기기의 제한적인 자원의 문제를 해결할 수 있다. 3-Tier 구조는 HAS(Hospital Authentication Server) 기반의 3-Tier 구조와 Guardian 기반의 3-Tier 구조가 연구되었다.

2.3 HAS 기반의 3-Tier 구조

HAS 기반의 3-Tier 구조는 그림 2와 같다.

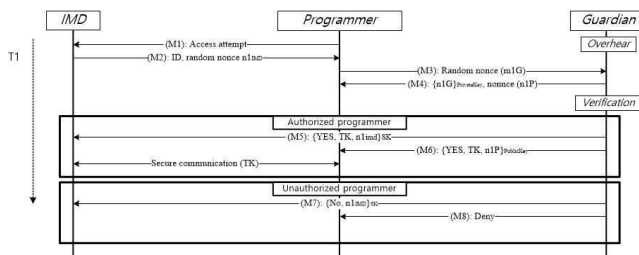


(그림 2) HAS 기반의 3-Tier 구조 모델

HAS 기반의 3-Tier 구조는 공개키를 활용하여 기밀성, 무결성, 상호인증을 만족했지만 제한된 자원을 활용하는 체내 이식형 의료기기의 특징상 공개키와 같은 과도한 연산 오버헤드를 감당하기 어렵다. 또한, 체내 이식형 의료기기의 ID와 Programmer의 ID가 무분별하게 공개되어 사칭공격이나 중간자 공격에 잠재적인 취약점을 갖는다.

2.4 Guardian 기반의 3-Tier 구조

Guardian 기반의 3-Tier 구조는 그림 3과 같다.



(그림 3) Guardian 기반의 3-Tier 구조

Guardian 기반의 3-Tier 구조는 임의의 난수와 공개키 암호화를 활용하여 세션키를 생성 및 활용하는 방식이다. 공개키 암호화와 같은 과도한 연산 오버헤드를 Guardian에게 위임하여 경량화 하였지만 프로토콜 상의 결함으로 인해 기밀성과 상호인증을 만족하지 못하였다. 체내 이식형 의료기기가 활용하는 정보가 노출될 경우 환자에게 치명적인 위협이 될 수 있다.

3. 체내 이식형 의료기기를 위한 안전한 인증 프로토콜 설계

3.1 용어 정리

본 장에서 활용하는 용어에 대한 정리는 표 1과 같다.

(표 1) 용어 정리

용어	의미
IMD	Implantable Medical Device
Programmer	의사가 IMD에 접근하기 위해 사용하는 기기
HAS	Hospital Authentication Server
dID	IMD의 ID
pID	Programmer의 ID
REQ / RES	REQuest / RESponse
SN(x)	x번 통신의 Session Number
L#(x)	x번 통신의 ID 리스트
K _i	Programmer가 세션키를 분배받기 위해 생성하는 키
K _{ri} / K _{wi}	Read 세션키 / Write 세션키
DATA	환자의 상태 정보
Auth	정보를 IMD에서 제공하였음을 증명하는 값
MAC(x)	x에 대한 메시지 인증 코드
SIGN	메시지에 대한 전자서명
conf	IMD의 동작을 수정하는 값
status	IMD의 상태 정보 값

3.2 보안 요구사항

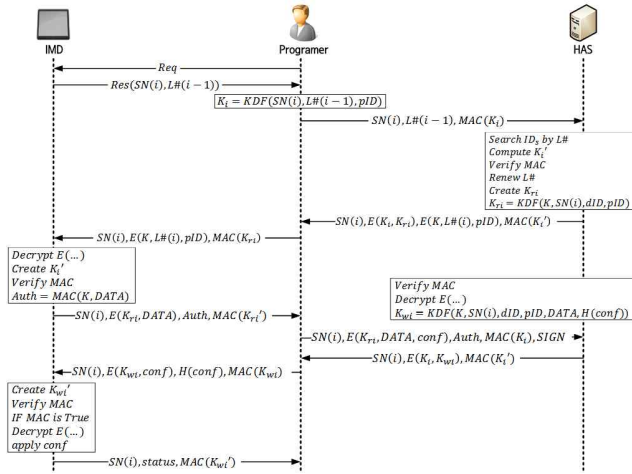
① 체내 이식형 의료기기는 환자의 신체정보, 병력, 상태정보 등의 다양한 개인정보를 활용하기 때문에 정보에 대한 기밀성, 무결성이 필요하다. 악의적으로 정보를 탈취하거나 위/변조할 경우 진료 및 처방에 오류가 생길 수 있으며 이는 환자에게 매우 치명적이다.

② 체내 이식형 의료기기를 활용하는 치료의 안전성을 위하여 상호인증을 통한 접근제어가 필수적이다. 악의적인 사용자가 Programmer를 통해 환자의 체내 이식형 의료기기의 오작동을 유발하여 환자의 생명에 치명적인 위협을 가할 수 있다[5].

3.3 체내 이식형 의료기기를 위한 안전한 인증 프로토콜

본 논문에서는 HAS 기반의 3-Tier 구조의 취약점인 보완하여 체내 이식형 의료기기의 ID와 Programmer의 ID가 무분별하게 공개되는 것을 방지하고 3자로부터 해당 체내 이식형 의료기기의 익명성을 보장하여 사칭공격과 중간자 공격으로부터 안전한 인증 프로토콜을 제안한다. 제안하는 인증 프로토콜은 그림 4와 같다.

- ① Programmer는 IMD에 접속하기 위해 REQ 메시지를 IMD에게 전송한다.
- ② IMD는 RES 메시지에 SN, L#을 포함하여 Programmer에게 전송한다.



(그림 4) 제안하는 인증 프로토콜

- ③ Programmer는 K_i 를 생성하고, $L\#$, SN 과 K_i 의 MAC 값을 HAS에게 전송한다.
- ④ HAS는 $L\#$ 를 이용하여 pID 와 dID 를 검색하고, K_i' 를 계산하여 MAC을 검증한다. 이후, $L\#$ 를 갱신하고, K_{ri} 를 생성한다.
- ⑤ HAS는 SN , K_{ri} 의 암호문, pID 의 암호문과 K_i' 의 MAC 값을 Programmer에게 전송한다.
- ⑥ Programmer는 K_{ri} 를 복호화하여 저장하고, SN , pID 의 암호문과 K_{ri} 의 MAC 값을 IMD에게 전송한다.
- ⑦ IMD는 pID 를 복호화하여 저장하고, K_{ri}' 를 생성하여 MAC을 검증한다. 그리고 인증 값인 $Auth$ 를 생성한다.
- ⑧ IMD는 SN , $DATA$ 의 암호문, $Auth$, K_{ri}' 의 MAC 값을 Programmer에게 전송한다.
- ⑨ Programmer는 SN , $conf$ 와 $DATA$ 의 암호문, $Auth$, K_i 의 MAC 값과 메시지의 $SIGN$ 을 HAS에게 전송한다.
- ⑩ HAS는 $SIGN$ 과 MAC을 검증하고, $DATA$ 와 $conf$ 를 복호화한다. 그리고 K_{wi} 를 계산한다.
- ⑪ HAS는 SN , K_{wi} 의 암호문, K_i' 의 MAC을 Programmer에게 전송한다.
- ⑫ Programmer는 SN , $conf$ 의 암호문과 해시 값, K_{wi} 의 MAC 값을 IMD에게 전송한다.
- ⑬ IMD는 K_{wi}' 를 계산하고, MAC을 검증한다. 그리고 $conf$ 를 복호화하고, 해시 값과 비교한다. $conf$ 가 올바르면 적용한다.
- ⑭ IMD는 SN 과 디바이스의 상태 정보인 $status$, K_{wi}' 의 MAC 값을 Programmer에게 전송한다.

4. 정형화 검증

4.1 AVISPA(Automated Validation of Internet Security Protocols and Applications)

AVISPA[6]는 프로토콜의 취약점을 분석하기 위한 정형화 검증 도구이며 하위 모듈을 통해 프로토콜을 검증한다. AVISPA는 프로토콜을 검증하기 위하여 정형화 언어인 HLPSP(High-Level Protocol Specification Language)로 프로토콜을 작성한다.

4.2 정형화 검증

그림 5는 제안하는 안전한 인증 프로토콜에 대한 HLPSP 명세 코드의 일부이다.

```

role role_IMD(
  IMD:agent,PROG:agent,HAS:agent,
  REQ:text,RES:text,LN1:text,SN:text,DATA:text,Stat:text,Auth:text,DID:text,
  K:symmetric_key,
  KDF:function,H:function,MAC:function,
  SND,RCV:channel(dy))
played_by IMD
def=
  local
    State:nat,
    PID:text,LN2:text,
    Kri:symmetric_key,
    Conf:text,
    Kwi:symmetric_key

  init
    State:=0

  transition
    1. State=0 & RCV(REQ) =>
      State:=1 & SND(RES,SN,LN1)
    5. State=1 & RCV(SN,{LN2'.PID'}_K.MAC(Kri')) =>
      State:=2 & secret(PID',sec_2,{IMD,PROG}) & SND(SN,{DATA}_Kri'.Auth.MAC(Kri'))
    9. State=2 & RCV(SN,{Conf'}_Kwi'.H(Conf').MAC(Kwi')) =>
      State:=3 & SND(SN.Stat.MAC(Kwi'))

end role
  
```

(그림 5) AVISPA 명세 코드

본 논문에서 제안하는 프로토콜을 검증하기 위하여 HLPSP 명세코드에는 다음과 같은 검증 코드를 포함하였다.

```

secret(DID',sec_1,{IMD,PROG})
secret(PID',sec_2,{IMD,PROG})
  
```

위의 코드는 각각 DID(체내 이식형 의료기기의 ID)와 PID(Programmer의 ID)가 체내 이식형 의료기기와 Programmer 사이의 통신에서 안전한지 검증하는 코드이다.

그림 6은 그림 5의 코드에 대한 검증 결과이다. 그림 5의 검증 결과에 따르면 제안하는 체내 이식형 의료기기를 위한 인증 프로토콜은 공격에 안전하다.

```

% OFMC
% Version of 2006/02/13
SUMMARY
SAFE
DETAILS
BOUNDED_NUMBER_OF_SESSIONS
PROTOCOL
/home/span/span/testsuite/results/hlpplGenFile.if
GOAL
as_specified
BACKEND
OFMC
COMMENTS
STATISTICS
parseTime: 0.00s
searchTime: 0.16s
visitedNodes: 148 nodes
depth: 11 plies
  
```

(그림 6) AVISPA 검증 결과

5. 결 론

본 논문에서는 기존 2-Tier 구조를 확장한 3-Tier 구조들 중에서 HAS 기반의 3-Tier 구조의 잠재적인 공격 취약점을 개선한 인증 프로토콜을 제안 및 프로토콜 정형화 검증 툴인 AVISPA를 통하여 검증하였다.

본 논문에서는 HAS 기반의 3-Tier 구조의 ID가 무분별하게 공개되는 취약점을 개선하기 위하여 HAS에 환자(IMD)와 의사(Programmer)를 묶어놓은 리스트를 작성하여 리스트의 번호인 L#을 ID의 대용으로 사용하였다. ID가 공개되는 것은 인증 과정 수행 시에 ID가 공개되어 사용자의 익명성의 침해와 사칭공격, 중간자공격의 잠재적 취약점이 된다[7]. 이 취약점은 ID를 L#으로 대체하는 것으로 해결할 수 있으며 L#은 해당 인증이 종료될 때 HAS에서 L#을 갱신하여 분배하여 L#를 통한 디바이스의 익명성을 보장하였다.

추후 연구에서는 여러 대의 체내 이식형 의료기기가 동시에 HAS에 접속할 경우 일어날 수 있는 인증 지연 및 병목 현상을 해결할 수 있는 방향으로 진행하려고 한다.

참 고 문 헌

- [1] 정재훈, 박성윤, 조은정, 허찬희, 박기정, 김동섭, 김성민, “이식형 유헬스 디바이스의 평가 연구,” 한국에프디시 법제학회, Vol.6, No.2, pp.79-84, 2011.
- [2] D. Halperin, T. S. Heydt-benjamin, K. Fu, T. Kohn o, and W. H. Maisel, “Security and Privacy for Implantable Medical Devices,” IEEE Pervasive Computing, vol. 7, no. 1, pp. 302-39, Jan. 2008.
- [3] N. Ellouze, M. Allouche, H. B. Ahmed, S. Rekhis, and N. Boudriga, “Security of implantable medical devices : limits, requirements, and proposals,” Security and Communication Networks, vol. 7, no. 12, pp.2475-2491, Dec. 2014.
- [4] 안승현, 박창섭, 박주호, “체내 이식형 의료기기의 보안성 향상을 위한 3-Tier 보안 메커니즘 설계,” 융합보안 논문지, vol. 14, no. 3, pp.11-19, May 2014.
- [5] D. Halperin, T. S. Heydt-benjamin, B. Ransford, S. S. Clark, B. Defend, W. Morgan, K. Fu, T. Kohn, and W. H. Maisel, “Pacemakers and Implantable Cardiac Defibrillators: Software Radio Attacks and Zero-Power Defenses,” Proc. of the IEEE Symposium on Security and Privacy, pp. 129-142, Oakland, CA, U.S.A., May 2008.
- [6] <http://www.avispa-project.org>
- [7] C. Camara, P. Peris-Lopez, and J. E. Tapiador, “Security and privacy issues in implantable medical devices: A comprehensive survey,” Journal of Biomedical Informatics 55, pp.272-289, 2015.